Analisi traffico – Wireshark

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	192.168.200.150	192.168.200.255	BROWSER	286	Host Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Xenix Server, NT Workstation, NT Server, Potential Browser
2	23.764214995	192.168.200.100	192.168.200.150	TCP	74	53060 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522427 TSecr=0 WS=128
3	23.764287789	192.168.200.100	192.168.200.150	TCP	74	33876 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522428 TSecr=0 WS=128
4	23.764777323	192.168.200.150	192.168.200.100	TCP	74	80 → 53060 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294951165 TSecr=810522427 WS=64
5	23.764777427	192.168.200.150	192.168.200.100	TCP	60	443 → 33876 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
6	23.764815289	192.168.200.100	192.168.200.150	TCP	66	53060 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
7	23.764899091	192.168.200.100	192.168.200.150	TCP	66	53060 → 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
8	28.761629461	PCSSystemtec_fd:87:…	PCSSystemtec_39:7d:…	ARP	60	Who has 192.168.200.100? Tell 192.168.200.150
9	28.761644619	PCSSystemtec_39:7d:…	PCSSystemtec_fd:87:…	ARP	42	192.168.200.100 is at 08:00:27:39:7d:fe
10	28.774852257	PCSSystemtec_39:7d:…	PCSSystemtec_fd:87:…	ARP	42	Who has 192.168.200.150? Tell 192.168.200.100
11	28.775230099	PCSSystemtec_fd:87:…	PCSSystemtec_39:7d:…	ARP	60	192.168.200.150 is at 08:00:27:fd:87:1e
12	36.774143445	192.168.200.100	192.168.200.150	TCP	74	41304 → 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
13	36.774218116	192.168.200.100	192.168.200.150	TCP	74	56120 → 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
14	36.774257841	192.168.200.100	192.168.200.150	TCP	74	33878 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
15	36.774366305	192.168.200.100	192.168.200.150	TCP	74	58636 → 554 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
16	36.774405627	192.168.200.100	192.168.200.150	TCP	74	52358 → 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
17	36.774535534	192.168.200.100	192.168.200.150	TCP	74	46138 → 993 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
18	36.774614776	192.168.200.100	192.168.200.150	TCP	74	41182 → 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
19	36.774685505	192.168.200.150	192.168.200.100	TCP	74	23 → 41304 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
20	36.774685652	192.168.200.150	192.168.200.100	TCP	74	111 → 56120 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
21	36.774685696	192.168.200.150	192.168.200.100	TCP	60	443 → 33878 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
22	36.774685737	192.168.200.150	192.168.200.100	TCP	60	554 → 58636 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
23	36.774685776	192.168.200.150	192.168.200.100	TCP	60	135 → 52358 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
24	36.774700464	192.168.200.100	192.168.200.150	TCP	66	41304 → 23 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
25	36.774711072	192.168.200.100	192.168.200.150	TCP	66	56120 → 111 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
26	36.775141104	192.168.200.150	192.168.200.100	TCP	60	993 → 46138 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
27	36.775141273	192.168.200.150	192.168.200.100	TCP	74	21 → 41182 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535438 WS=64
28	36.775174048	192.168.200.100	192.168.200.150	TCP	66	41182 → 21 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
29	36.775337800	192.168.200.100	192.168.200.150	TCP	74	59174 → 113 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
30	36.775386694	192.168.200.100	192.168.200.150	TCP	74	55656 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128
31	36.775524204	192.168.200.100	192.168.200.150	TCP	74	53062 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128
32	36.775589806	192.168.200.150	192.168.200.100	TCP	60	113 → 59174 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
33	36.775619454	192.168.200.100	192.168.200.150	TCP	66	41304 → 23 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
34	36.775652497	192.168.200.100	192.168.200.150	TCP	66	56120 → 111 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
35	36.775790038	192.168.200.150	192.168.200.100	TCP	74	22 → 55656 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535439 WS=64
36	36.775797004	192.168.200.150	192.168.200.100	TCP	74	80 → 53062 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535439 WS=64
37	36.775803786	192.168.200.100	192.168.200.150	TCP	66	55656 → 22 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
38	36.775813232	192.168.200.100	192.168.200.150	TCP	66	53062 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
39	36.775861964	192.168.200.100	192.168.200.150	TCP	66	41182 → 21 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466

L'evidenza principale è un **TCP SYN Scan** in corso.

- **Attaccante (Source IP):** 192.168.200.100
- **Vittima (Target IP):** 192.168.200.150

Partendo dal primo pacchetto si nota la presenza di un *Host Announcement* tramite protocollo BROWSER dove la macchina vittima si identifica come "METASPLOITABLE".

A seguito si nota una serie di richieste TCP con il flag [SYN] verso molteplici porte della vittima, i pacchetti evidenziati in rosso mostrano la vittima che risponde con [RST, ACK], indicando che la porta scansionata è chiusa. I pacchetti in cui l'attaccante invia un successivo [ACK] implicano che la vittima aveva precedentemente risposto con un [SYN, ACK], confermando che quella specifica porta è aperta e in ascolto.

I dati indicano che l'attaccante sta sondando la rete con un tool automatico (probabilmente *Nmap*) per mappare le porte del target.

Per contenere questo scenario:

- **Network Firewalling:** Implementare una regola per bloccare immediatamente tutto il traffico in ingresso dall'attaccante (192.168.200.100).
- **Intrusion Prevention System (IPS):** Configurare regole basate su soglie per rilevare e mitigare automaticamente i *Port Scan*. Ad esempio, limitare il numero di pacchetti SYN ricevibili da un singolo IP al secondo.
- **Network Segmentation:** Essendo la vittima una macchina "Metasploitable", dovrebbe essere isolata in una *VLAN* dedicata agli host vulnerabili, qualora sia ancora utilizzata.

Cos'è il CSIRT Italia (ACN)? Il *Computer Security Incident Response Team* (CSIRT) Italia è la struttura tecnico-operativa dell'Agenzia per la Cybersicurezza Nazionale (ACN). Costituisce il punto di contatto centrale a livello nazionale per la gestione e la risposta agli incidenti informatici.

Quali sono i suoi compiti? I compiti si concentrano sull'intero ciclo di vita della minaccia:

- **Threat Intelligence e Monitoraggio:** Analisi continua delle minacce cibernetiche a livello nazionale e internazionale.
- **Early Warning:** Diffusione di allerte, bollettini di sicurezza e indicatori di compromissione (IoC) per avvisare tempestivamente gli stakeholder.
- **Incident Response:** Coordinamento delle attività di risposta agli attacchi informatici, specialmente se diretti verso infrastrutture critiche, Pubblica Amministrazione o enti privati di rilevanza strategica.
- **Supporto Tecnico:** Fornitura di linee guida e supporto specialistico per il contenimento, la mitigazione delle vulnerabilità e il ripristino dei sistemi compromessi.

Analisi dell'allerta AL03-240322/CSIRT-ITA (Campagna "Sondaggio Trenitalia")

Questa specifica allerta documenta un classico attacco di *Phishing* orientato al furto di credenziali e alle frodi finanziarie, che utilizza l'immagine del brand Trenitalia. Il vettore di attacco è la distrubuzione di email adescative, invitando la vittima a partecipare a un finto sondaggio sulla qualità dei servizi offerti dall'azienda, promettendo in premio un pass annuale gratuito per viaggiare sui treni. Al termine del sondaggio, l'utente viene reindirizzato su una pagina di "riscossione" della finta vincita. Qui vengono sottratte informazioni personali e, per pagare le "spese di spedizione", viene richiesto l'inserimento degli estremi della carta di credito.

Come proteggere l'organizzazione da questa campagna phishing:

- **Email Security Gateway (ESG):** Assicurarsi che i sistemi antispam filtrino le comunicazioni contenenti domini o URL riconducibili al finto sondaggio.
- **DNS Filtering / Web Proxy:** Inibire la navigazione a livello perimetrale verso gli URL e gli indirizzi IP malevoli.
- **Security Training:** Istruire continuamente i dipendenti a riconoscere i *Red Flag* del phishing.